

Informe PASTA.

El informe PASTA, dices. Muy bien: saquemos la vajilla buena, porque aquí no vamos a hablar de “checklists” sino de cómo convertir STRIDE y PASTA en maquinaria pesada de política pública para un país entero, empezando por España y mirando de reojo al resto del planeta.

1. Recordatorio mínimo: qué es PASTA y por qué importa en 2026

PASTA (Process for Attack Simulation and Threat Analysis) es una metodología de modelado de amenazas en siete etapas, explícitamente centrada en el riesgo y en el impacto de negocio, no solo en la vulnerabilidad técnica. Frente a otros enfoques, insiste en alinear requisitos de seguridad con objetivos empresariales y de misión, y en ligar cada amenaza a escenarios de ataque y análisis de impacto.¹²³

Las siete fases, en su formulación “clásica” y en las versiones consolidadas hasta 2025–2026, se agrupan así: definición de objetivos de negocio, alcance técnico, descomposición de la aplicación y sus flujos de datos, análisis de amenazas, análisis de vulnerabilidades/debilidades, modelado/simulación de ataques y, finalmente, análisis de riesgo e impacto.⁴⁵⁶⁷

Esta orientación hace que PASTA encaje bien con marcos de gestión de riesgo a gran escala (NIST, ISO 27005, marcos nacionales de ciberseguridad) y con visiones Zero Trust que requieren entender flujos, dependencias y efectos en cascada, no solo parches aislados.⁸⁹¹⁰

1 <https://www.purestorage.com/es/knowledge/pasta-threat-modeling.html>

2 <https://www.purestorage.com/la/knowledge/pasta-threat-modeling.html>

3 <https://www.fortinet.com/lat/resources/cyberglossary/threat-modeling>

4 <https://www.magazcitum.com.mx/index.php/archivos/6011>

5 <https://destcert.com/resources/threat-modeling-methodologies/>

6 <https://www.fortinet.com/lat/resources/cyberglossary/threat-modeling>

7 <https://www.linkedin.com/pulse/enterprise-threat-modeling-methodologies-stride-vs-pasta-basharat-tchjf>

8 <https://www.lrq.com/es-es/modelado-de-amenazas/>

9 <https://ciberseguridadtic.es/reportajes/zero-trust-quince-anos-de-un-modelo-que-cambio-la-ciberseguridad-2025091610242.htm>

10 <https://www.fortinet.com/lat/resources/cyberglossary/threat-modeling>

2. STRIDE como “lenguaje” de amenazas dentro de PASTA

STRIDE (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) sigue siendo en 2025–2026 el alfabeto básico para clasificar amenazas a nivel de componentes y flujos, sobre todo cuando se trabaja con diagramas de flujo de datos y límites de confianza.¹¹¹²¹³

La tendencia clave desde 2025 no es “PASTA versus STRIDE”, sino combinarlos: PASTA para la narrativa de riesgo de negocio y el ciclo en siete etapas, STRIDE para etiquetar técnicamente las amenazas en las fases 4–6. En la práctica, muchas guías y white papers recientes recomiendan exactamente eso: emplear STRIDE como catálogo de amenazas dentro del análisis de amenazas y el modelado de ataques de PASTA, y luego pasar a métricas de impacto más cercanas al negocio (likelihood/impact, matrices de riesgo, DREAD, etc.).¹⁴¹⁵¹⁶¹⁷¹⁸

3. De “fases” a “indicadores”: qué se está midiendo realmente en PASTA+STRIDE

A partir de 2025 se ven tres grandes líneas en la evolución de indicadores y métricas asociadas al uso de PASTA y STRIDE:

1. Métricas de cobertura del modelo de amenazas: qué tanto del sistema y de las categorías STRIDE están realmente abordadas.
2. Métricas de riesgo cuantitativo: probabilidad/impacto, a menudo con inspiración en DREAD o matrices de riesgo cualitativas que se usan en informes a dirección.⁹³
3. Métricas de desempeño y madurez del proceso: tiempos de reacción, integración en DevSecOps, uso de automatización y simulaciones continuas.¹³¹²⁹

3.1 Indicadores por fase de PASTA

Resumiendo lo que se ve en documentación técnica y guías recientes:

¹¹ <https://destcert.com/resources/threat-modeling-methodologies/>

¹² <https://www.fortinet.com/lat/resources/cyberglossary/threat-modeling>

¹³ <https://www.magazcitum.com.mx/index.php/archivos/6011>

¹⁴ <https://www.isaca.org/resources/white-papers/2025/threat-modeling-revisited>

¹⁵ <https://www.linkedin.com/pulse/enterprise-threat-modeling-methodologies-stride-vs-pasta-basharat-tchjf>

¹⁶ <https://www.lrqa.com/es-es/modelado-de-amenazas/>

¹⁷ <https://www.iriusrisk.com/resources-blog/threat-modeling-methodology-stride>

¹⁸ <https://www.fortinet.com/lat/resources/cyberglossary/threat-modeling>

- Fase 1 (Objetivos de negocio): número de objetivos de ciberseguridad trazados explícitamente a objetivos estratégicos, y porcentaje de escenarios de amenaza que se mapean a regulaciones o requisitos (NIS2, ENS, GDPR, etc.).6173
- Fase 2 (Alcance técnico): porcentaje de activos y componentes en el entorno que aparecen en el modelo (cobertura de activos), cobertura de flujos de datos críticos, y nivel de detalle de la arquitectura documentada.2136
- Fase 3 (Descomposición): número de flujos con límites de confianza claramente identificados, porcentaje de aplicaciones con diagramas de datos actualizados.3116
- Fase 4 (Análisis de amenazas): número de amenazas identificadas por categoría STRIDE por aplicación/sistema; densidad de amenazas por flujo de datos; uso de fuentes de inteligencia de amenazas (CTI, OWASP Top 10, etc.).1293
- Fase 5 (Vulnerabilidades/debilidades): porcentaje de amenazas con vulnerabilidad asociada, tiempo medio de cierre de vulnerabilidades ligadas a escenarios PASTA frente al resto, correlación con CVSS.12113
- Fase 6 (Modelado/simulación de ataques): número de escenarios de ataque simulados por ciclo, porcentaje de ellos que cubren los activos críticos, y frecuencia de actualización de los escenarios ante cambios en arquitectura o inteligencia de amenazas.1163
- Fase 7 (Análisis de riesgo/impacto): distribución de amenazas por nivel de riesgo (bajo/medio/alto/crítico), valor económico estimado en riesgo (por ejemplo, pérdida anualizada), y porcentaje de riesgos críticos con plan de mitigación aprobado.9123

3.2 Métricas STRIDE “modernizadas”

A nivel de STRIDE, los indicadores que se consolidan desde 2025 combinan cantidad, severidad y cobertura:

- Spoofing: número de identidades o credenciales susceptibles de suplantación, porcentaje de servicios críticos sin MFA o sin autenticación robusta, y frecuencia de incidentes de suplantación detectados.1012
- Tampering: porcentaje de flujos sin integridad garantizada, incidentes de integridad por periodo, madurez de controles de integridad en datos en tránsito y en reposo.1012
- Repudiation: porcentaje de transacciones críticas sin trazabilidad suficiente, brechas de logging y monitoreo, incidentes en los que no se pudo atribuir acciones.910
- Information disclosure: volumen de datos sensibles en sistemas y flujos, número de exposiciones significativas, superficie de exposición desde Internet.12109
- Denial of service: disponibilidad medida (SLA/SLO), número de eventos de degradación severa, capacidad de absorción ante picos (tests de estrés y simulaciones).1012
- Elevation of privilege: número de caminos de escalado de privilegios identificados en escenarios PASTA, porcentaje de cuentas con privilegios excesivos, incidentes de abuso de privilegios.12910

Estos indicadores se suelen combinar en matrices de riesgo o en modelos tipo DREAD (Daño, Reproducibilidad, Explotabilidad, Usuarios afectados, Descubribilidad), puntuando cada amenaza de 1 a 10 y promediando para priorizar mitigaciones.¹⁹²⁰

4. Tendencias recientes (2025–2026): del proyecto a la escala país

En el plano global y nacional se observan varias tendencias relevantes para tu escenario de “España país Zero Trust que hace PASTA en macro”:

4.1 Integración con marcos de ciberseguridad nacionales y sectoriales

El Gobierno de España ha reforzado desde 2024–2025 su apuesta por la ciberseguridad como componente de estrategia digital y defensa, con un Plan Nacional de Ciberseguridad y medidas específicas que citan la necesidad de proteger infraestructuras críticas, adaptar capacidades a IA y computación cuántica, y consolidar centros de ciberseguridad. Aunque los documentos oficiales no invocan PASTA por nombre, sí exigen enfoques basados en riesgo que encajan perfectamente con él: identificación de activos críticos, análisis de amenazas, priorización de riesgos y simulaciones de escenarios.²¹²²²³²⁴

En paralelo, informes como “El estado de la ciberseguridad en España 2026” destacan la necesidad de enfoques continuos, automatizados y basados en simulaciones, señalando que las revisiones de proveedores siguen siendo mayoritariamente documentales y que las simulaciones reales son aún minoritarias. Ese “todavía minoritario” es básicamente una invitación a generalizar prácticas tipo PASTA (simulación de ataques y análisis de amenazas) más allá de pruebas ad hoc.²⁵

A nivel europeo, la evolución de NIS2 y la estrategia “Digital Spain 2025” refuerzan el énfasis en protección de infraestructuras críticas, capacidades de respuesta y resiliencia, y necesidades de talento

¹⁹ <https://ciberseguridadtic.es/reportajes/zero-trust-quince-anos-de-un-modelo-que-cambio-la-ciberseguridad-2025091610242.htm>

²⁰ <https://destcert.com/resources/threat-modeling-methodologies/>

²¹ <https://www.linkedin.com/pulse/enterprise-threat-modeling-methodologies-stride-vs-pasta-basharat-tchjf>

²² <https://www.isaca.org/resources/white-papers/2025/threat-modeling-revisited>

²³ <https://apiiro.com/blog/stride-vs-dread-vs-pasta-choosing-the-right-threat-modeling-framework/>

²⁴ <https://www.isaca.org/resources/white-papers/2025/threat-modeling-revisited>

²⁵ <https://www.iriusrisk.com/resources-blog/threat-modeling-methodology-stride>

avanzado, lo que requiere marcos de modelado de amenazas capaces de escalar de sistemas individuales a ecosistemas nacionales.²⁶²⁷²⁸

4.2 “Híbridos” STRIDE–PASTA en entorno empresarial y regulatorio

En el ámbito empresarial internacional, white papers y análisis recientes señalan que las organizaciones maduras tienden a combinar STRIDE para descubrimiento técnico de amenazas, PASTA para el hilo narrativo de riesgo de negocio y, en algunos casos, DREAD o matrices de riesgo para la dimensión cuantitativa.²⁹³⁰³¹³²

Esta combinación se está promoviendo explícitamente como “modelo híbrido” que conecta riesgos técnicos detectados en aplicaciones (STRIDE aplicado a flujos y componentes) con resultados de negocio y métricas de riesgo empleadas por GRC y consejos de administración (las últimas fases de PASTA).³³³⁴³⁵³⁶

5. España como laboratorio: indicadores PASTA+STRIDE a nivel territorial

Si uno se toma en serio el “PASTA a nivel país”, los indicadores dejan de ser meras estadísticas de una aplicación y se convierten en instrumentos de supervisión macro.

A partir de las estrategias y estudios españoles recientes se pueden identificar dimensiones en las que encajar los indicadores PASTA+STRIDE: protección de infraestructuras críticas, nivel de madurez de

26 <https://www.isaca.org/resources/white-papers/2025/threat-modeling-revisited>

27 <https://apiiro.com/blog/stride-vs-dread-vs-pasta-choosing-the-right-threat-modeling-framework/>

28 <https://www.practical-devsecops.com/types-of-threat-modeling-methodology/>

29 <https://www.isaca.org/resources/white-papers/2025/threat-modeling-revisited>

30 <https://www.fortinet.com/lat/resources/cyberglossary/threat-modeling>

31 <https://destcert.com/resources/threat-modeling-methodologies/>

32 <https://apiiro.com/blog/stride-vs-dread-vs-pasta-choosing-the-right-threat-modeling-framework/>

33 <https://www.fortinet.com/lat/resources/cyberglossary/threat-modeling>

34 <https://www.isaca.org/resources/white-papers/2025/threat-modeling-revisited>

35 <https://destcert.com/resources/threat-modeling-methodologies/>

36 <https://www.deloitte.com/es/es/services/consulting/research/estado-ciberseguridad.html>

organizaciones, capacidades de respuesta, talento y ecosistema de centros de ciberseguridad, y resiliencia sectorial.³⁷³⁸³⁹⁴⁰⁴¹

5.1 Ejemplos de indicadores (España, nacional-territorial) inspirados en PASTA

4. Cobertura de modelado de amenazas:

- Porcentaje de organismos de la Administración General del Estado y operadores de servicios esenciales que aplican metodologías de modelado de amenazas (PASTA, STRIDE, etc.) en sus sistemas críticos.¹⁴¹⁵¹³
- Número de sectores regulados con guías oficiales o de INCIBE/CCN que recomiendan explícitamente modelado de amenazas basado en riesgo.¹⁷¹⁵¹⁴

5. Métricas STRIDE agregadas:

- Tasa de incidentes de suplantación de identidad y fraude (Spoofing) notificados a organismos nacionales, por millón de usuarios, correlacionada con adopción de MFA y esquemas de identidad digital.¹⁵¹⁶¹⁴
- Número de incidentes de fuga de información reportados (Information disclosure), comparado con exposición de datos personales y sectoriales.¹⁶¹⁴¹⁵
- Eventos de denegación de servicio significativos sobre servicios públicos y sectores críticos, medidos en duración y alcance (Denial of service).¹⁴¹⁶

6. Madurez de simulación de ataques:

- Porcentaje de operadores de infraestructuras críticas que realizan simulaciones de ataque (red teaming, ejercicios PASTA, crisis nacionales) al menos una vez al año, y número de lecciones aprendidas traducidas a cambios de arquitectura.¹³¹⁴

7. Resiliencia y continuidad de negocio a escala país:

- Tiempo medio de recuperación de servicios esenciales ante incidentes muy graves (como los que el Gobierno cifra en “uno cada tres días” a nivel de país).¹⁴
- Porcentaje de entidades que vinculan explícitamente resultados de simulaciones y análisis de amenazas a planes de continuidad y ejercicios de crisis.¹³¹⁴

5.2 Comparativa internacional

A nivel comparado, el propio Gobierno de España presume —con cierta razón— de que el país figura por encima de la media comunitaria en los índices de ciberseguridad de la Unión Internacional de Telecomunicaciones, situándose como uno de los países con más centros de ciberseguridad, solo por detrás de Estados Unidos. Esto indica un ecosistema fértil para métricas avanzadas tipo PASTA, aunque los informes de consultoras y análisis de competencias en España aún subrayan brechas de talento y la

³⁷ <https://apiiro.com/blog/stride-vs-dread-vs-pasta-choosing-the-right-threat-modeling-framework/>

³⁸ <https://destcert.com/resources/threat-modeling-methodologies/>

³⁹ <https://www.linkedin.com/pulse/enterprise-threat-modeling-methodologies-stride-vs-pasta-basharat-tchjf>

⁴⁰ https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

⁴¹ <https://www.practical-devsecops.com/types-of-threat-modeling-methodology/>

necesidad de mejor integración de capacidades de ciberseguridad y análisis de amenazas en políticas nacionales.⁴²⁴³⁴⁴⁴⁵

Frente a otros países, la ventaja comparativa no está tanto en el volumen bruto de inversión, sino en la posibilidad de integrar marcos de riesgo (PASTA, STRIDE, Zero Trust) en un marco regulatorio coherente (NIS2, ENS, Estrategia Nacional de Ciberseguridad, Digital Spain 2025) donde se pueden exigir métricas homogéneas a operadores de servicios esenciales y a la administración.⁴⁶⁴⁷⁴⁸⁴⁹

6. Tabla sintética: STRIDE dentro de PASTA, del sistema al país

A efectos de claridad comparativa, puede ser útil condensar el diálogo PASTA–STRIDE y la traducción a indicadores nacionales:

42 <https://www.isaca.org/resources/white-papers/2025/threat-modeling-revisited>

43 <https://apiiro.com/blog/stride-vs-dread-vs-pasta-choosing-the-right-threat-modeling-framework/>

44 <https://www.practical-devsecops.com/types-of-threat-modeling-methodology/>

45 <https://www.linkedin.com/pulse/enterprise-threat-modeling-methodologies-stride-vs-pasta-basharat-tchjf>

46 <https://cyberhubs.eu/wp-content/uploads/2025/02/FINAL-2.3-SPAIN-CybersecuritySkillsStrategies.pdf>

47 <https://apiiro.com/blog/stride-vs-dread-vs-pasta-choosing-the-right-threat-modeling-framework/>

48 <https://www.isaca.org/resources/white-papers/2025/threat-modeling-revisited>

49 <https://www.linkedin.com/pulse/enterprise-threat-modeling-methodologies-stride-vs-pasta-basharat-tchjf>

Dimensión	PASTA (fase)	STRIDE	Métrica típica (sistema)	Métrica análoga (España, nacional/territorial)
Identidad	4-6 (amenazas, ataques) 36	Spoofing 10	Nº de flujos sin MFA, amenazas de suplantación detectadas 310	Incidentes de suplantación por millón de usuarios; adopción de MFA en servicios públicos y críticos 1416
Integridad	4-6 36	Tampering 10	Nº de flujos sin controles de integridad, incidencias de manipulación 310	Eventos de manipulación de datos en registros públicos y servicios esenciales por año 1416
Trazabilidad	3-5 36	Repudiation 10	% de transacciones críticas sin logging robusto 910	% de organismos que cumplen con requisitos mínimos de registro y conservación de evidencias 1416
Confidencialidad	4-5 36	Info. disclosure 10	Nº de amenazas de fuga de datos, fugas reales 310	Fugas de datos notificadas, volumen de registros afectados, por sector 1416
Disponibilidad	6-7 36	DoS 10	Nº y duración de eventos de indisponibilidad 310	Incidentes de indisponibilidad grave en servicios esenciales, media de recuperación 14
Privilegios	4-6 36	Elevation of privilege 10	Nº de caminos de escalado identificados, cuentas con privilegios excesivos 310	Incidentes de abuso de privilegios en AA.PP. y operadores críticos, % de cuentas privilegiadas auditadas 1416

7. Cómo encaja esto con Zero Trust y resiliencia digital

El modelo Zero Trust, consolidado como estándar de referencia con NIST SP 800-207 y guías de CISA, ha ido desplazando la clásica seguridad perimetral hacia un enfoque centrado en identidades, dispositivos, datos y contexto de acceso. En este contexto, PASTA y STRIDE son herramientas de análisis de amenazas y riesgo que permiten traducir los principios de “nunca confíes, verifica siempre” a escenarios concretos: rutas de ataque, abuso de identidades, manipulación de datos, denegaciones de servicio dirigidas a componentes críticos, etc.⁵⁰⁵¹⁵²

Los informes españoles y europeos insisten en la convergencia de funciones de red y seguridad (SASE/SSE), la necesidad de integrar ciberseguridad en la estrategia empresarial y en la continuidad de negocio, y en el rol clave de la automatización y la orquestación. PASTA, al enfatizar simulación de ataques y análisis iterativo, se adapta bien a entornos donde los controles se despliegan como código y las decisiones se basan en telemetría en tiempo (casi) real.⁵³⁵⁴⁵⁵

8. Recomendaciones propositivas (sin perder el tono)

Ya que pides algo “propositivo y constructivo”, algunas líneas de acción que emergen de las tendencias observadas:

⁵⁰ <https://ciberseguridadtic.es/reportajes/zero-trust-quince-anos-de-un-modelo-que-cambio-la-ciberseguridad-2025091610242.htm>

⁵¹ [http://espanadigital.gob.es/sites/espanadigital/files/2025-06/Informe de país 2024 de la Década Digital - España.pdf](http://espanadigital.gob.es/sites/espanadigital/files/2025-06/Informe%20de%20pa%C3%ADs%202024%20de%20la%20D%C3%A9cada%20Digital%20-%20Espa%C3%91a.pdf)

⁵² <https://www.fortinet.com/lat/resources/cyberglossary/threat-modeling>

⁵³ <https://ciberseguridadtic.es/reportajes/zero-trust-quince-anos-de-un-modelo-que-cambio-la-ciberseguridad-2025091610242.htm>

⁵⁴ <https://www.isaca.org/resources/white-papers/2025/threat-modeling-revisited>

⁵⁵ https://portal.mineco.gob.es/RecursosArticulo/mineco/ministerio/ficheros/210204_Digital_Spain_2025.pdf

8. Normalizar PASTA+STRIDE en guías nacionales:

La Estrategia Nacional de Ciberseguridad y el ENS podrían incorporar, en anexos técnicos, recomendaciones claras sobre uso de PASTA y STRIDE para sistemas de alto nivel, incluyendo ejemplos sectoriales. Eso reduciría la actual dependencia de cuestionarios y autoevaluaciones poco dinámicas que apuntan informes como el de Deloitte.¹⁷¹⁵¹³¹⁴

9. Definir un conjunto mínimo de indicadores PASTA+STRIDE para operadores esenciales:

El regulador podría exigir un pequeño núcleo de métricas estándar (por ejemplo, número de amenazas STRIDE por servicio crítico, escenarios PASTA simulados por año, tiempo de cierre de vulnerabilidades ligadas a dichos escenarios) que permita comparar madurez entre sectores.⁹¹³³¹⁴

10. Integrar PASTA en ejercicios nacionales de ciber crisis:

Los ejercicios coordinados de ciberseguridad y continuidad de negocio podrían apoyarse en escenarios preconstruidos en PASTA, vinculando explícitamente ataques simulados con métricas de impacto y continuidad, y alimentando así indicadores nacionales de resiliencia.¹⁵¹⁴

11. Invertir donde España flaquea: talento y automatización:

Las estrategias de competencias destacan carencias en perfiles avanzados de ciberseguridad; dotar a esos perfiles de formación formal en modelado de amenazas (PASTA, STRIDE, DREAD, etc.) sería coherente con los objetivos de Digital Spain 2025 y las metas de nuevos especialistas en ciberseguridad, IA y datos.¹⁷¹⁵

12. Promover transparencia estadística:

Los datos de incidentes que el Gobierno ya maneja —por ejemplo, los más de 100.000 ciberataques anuales y el aumento del 300% desde 2015— podrían desglosarse sistemáticamente según dimensiones STRIDE y sectores, permitiendo una lectura mucho más afinada del riesgo país y una evaluación de políticas basada en evidencia.¹⁴

18192021222324252627282930